

PROJET AIS

Procédure de déploiement standard

Provisioning, durcissement et validation des serveurs de l'infrastructure

Infrastructure applicative sécurisée — 02 août 2026

Classification	Confidentiel — Usage interne
Version	260802
Statut	A valider

	Nom	Date
Rédaction	Thomas Michel	02/08/26
Validation	Xx	Xx

Version	Changement	Rédaction	Validation
260802	Rédaction initiale	Thomas Michel	Xx

Table des matières

Table des matières	2
2. Introduction	3
2.1 Pourquoi une procédure de déploiement sécurisée ?	3
2.2 Périmètre	3
3. Procédure de déploiement	3
3.1 Prérequis	3
3.2 Provisioning du serveur	4
3.3 Durcissement du système d'exploitation	4
3.4 Rattachement au segment réseau	4
3.5 Authentification SSH par PKI	4
3.6 Pare-feu local (iptables)	4
3.7 Déploiement applicatif	5
3.8 Journalisation	5
3.9 Sauvegarde	5
4. Liste de tests	6
4.1 Tests de connectivité et de conformité réseau	6
4.2 Tests d'authentification	6
4.3 Tests fonctionnels applicatifs	6
4.4 Tests de conformité sécurité	6
4.5 Checklist récapitulative	6
4.6 Références	7

1. Historique des changements

260802 : Rédaction initiale du document.

2. Introduction

2.1 Pourquoi une procédure de déploiement sécurisée ?

Un serveur déployé sans checklist, sans ordre défini et/ou sans validation finale introduit une variance non maîtrisée dans la posture de sécurité de l'infrastructure. Chaque écart entre deux déploiements successifs (un port oublié, une authentification par mot de passe non désactivée, une règle de pare-feu manquante) constitue une surface d'attaque potentielle qui échappe à la documentation officielle et donc à l'audit/la surveillance.

La présente procédure vise à :

- **Garantir la reproductibilité** : deux administrateurs différents, à des dates différentes, doivent aboutir au même état de sécurisation pour un même rôle de serveur.
- **Réduire la fenêtre d'exposition** : un serveur ne doit jamais être raccordé à un segment réseau actif avant que son durcissement de base (SSH, pare-feu local) ne soit terminé.
- **Faciliter l'audit et la conformité** : une procédure documentée et suivie est la preuve matérielle exigée par plusieurs référentiels (voir §4.6) qu'un contrôle de sécurité a bien été appliqué avant mise en production, et non constaté a posteriori.
- **Limiter l'erreur humaine** : la majorité des incidents de sécurité en environnement maîtrisé proviennent d'une étape de configuration oubliée plutôt que d'une vulnérabilité inconnue (0-day). Une checklist transforme un risque de mémoire en un risque de process, qui se corrige.
- **Séparer le provisioning de la mise en production** : un serveur qui a été exposé, même brièvement, avec sa configuration par défaut avant durcissement doit être considéré comme potentiellement compromis et traité comme tel — d'où l'exigence d'un ordre d'opérations strict (cf. §3).

2.2 Périmètre

Cette procédure s'applique à tout nouveau serveur intégré à l'infrastructure du projet et tout ajout futur, qu'il s'agisse d'un serveur virtualisé (VM) ou d'une machine dédiée. Elle ne couvre pas la configuration du pare-feu périmétrique PfSense lui-même.

3. Procédure de déploiement

L'ordre ci-dessous est impératif. Chaque étape verrouille un risque avant que l'étape suivante n'expose davantage le serveur.

3.1 Prérequis

Élément	Détail
Hyperviseur	Hôte de virtualisation avec KVM/libvirt opérationnel
Image de base	Image Debian officielle, checksum vérifié avant usage
Autorité de certification SSH	CA hôte et CA utilisateur générées et disponibles
Accès administrateur	Compte root disponible pour les opérations nécessitant des privilèges élevés (les comptes applicatifs ne sont pas dans le groupe sudoers)
Segment réseau cible	Réseau virtuel isolé (libvirt) déjà créé et rattaché à l'interface PfSense correspondante
Snapshot de référence	Prise d'un instantané du serveur juste après provisioning, avant durcissement, pour permettre un retour arrière rapide

3.2 Provisioning du serveur

- Créer le serveur (VM ou machine dédiée) en l'attachant uniquement à un réseau isolé (jamais directement à un réseau exposé à l'extérieur).
- Installer le système avec un utilisateur non privilégié dédié (et nominatif).
- Noter l'adresse MAC de l'interface réseau (utile ensuite pour l'assignation d'interface côté PfSense).
- Prendre un snapshot immédiatement après l'installation de base, avant toute exposition réseau élargie.

3.3 Durcissement du système d'exploitation

- Configurer le PATH pour les utilisateurs si nécessaire (/sbin et /usr/sbin peuvent être absents du PATH par défaut sur Debian).
- Vérifier et restreindre les paramètres réseau du noyau pertinents dans /proc/sys/net/ipv4/ (désactiver ip_forward sauf besoin explicite, etc.).
- Configurer sshd avant tout rattachement réseau élargi :
 - Port non standard (2222/tcp) : mesure d'obscurcissement.
 - PermitRootLogin no
- Désactiver ou supprimer les services non nécessaires au rôle du serveur.

3.4 Rattachement au segment réseau

- Ne raccorder le serveur au segment réseau isolé cible qu'une fois l'étape 3.3 terminée.
- Assigner l'interface pfSense correspondante en faisant correspondre l'adresse MAC à l'interface côté pfSense.
- Vérifier qu'aucune règle pare-feu pfSense par défaut n'autorise plus que le strict nécessaire (politique deny-all par défaut sur chaque interface).
- Confirmer la résolution DNS interne (/etc/resolv.conf pointant vers le résolveur pfSense) et la synchronisation NTP.
- Mettre à jour le système (apt update && apt upgrade).

3.5 Authentification SSH par PKI

- Récupérer la clé d'hôte du nouveau serveur (ssh_host_ed25519_key.pub).
- Signer la clé d'hôte avec la CA hôte (ssh-keygen -s ssh_ca -I "<id>-host" -h -n <IP>,<hostname> -V +52w).
- Déployer le certificat d'hôte signé et référencer HostCertificate dans sshd_config.
- Déployer la clé publique de la CA utilisateur et déclarer TrustedUserCAKeys.
- Appliquer le durcissement d'authentification : PasswordAuthentication no, AuthorizedKeysFile none, AuthenticationMethods publickey.
- Redémarrer sshd et valider la connexion par certificat avant de retirer tout accès de secours.

⚠ Point de vigilance — le déploiement de ssh_ca.pub sur le serveur doit précéder toute référence à ce fichier dans sshd_config, sous peine d'échec de sshd au redémarrage.

3.6 Pare-feu local (iptables)

- Autoriser explicitement les flux nécessaires au rôle du serveur uniquement (ex. : 2222/tcp restreint à la source légitime, port applicatif).
- Définir une politique INPUT DROP par défaut (après avoir autorisé la connection par ssh si fait via ssh).
- Ne pas utiliser -F (flush) complet sur un serveur exécutant Docker : Docker gère ses propres chaînes et un flush casse le routage des conteneurs.
- Documenter les règles dans un script versionné (iptables_<hostname>.sh) et assurer la persistance au redémarrage.

3.7 Déploiement applicatif

Étape spécifique au rôle du serveur (hors socle commun ci-dessus) :

Rôle	Éléments à déployer
SRV-1 (applicatif)	Application Flask, environnement virtuel Python, service exécuté sous utilisateur non privilégié
SRV-2 (BDD)	PostgreSQL (conteneur Docker), rôle applicatif dédié à moindre privilège (jamais le rôle superutilisateur), secrets dans .env non versionné
Backup	Pipeline Borg (init du dépôt avec repokey-blake2), passphrase et identifiants stockés en chmod 600, timer systemd
Bastion	Point de rebond SSH unique, journalisation de session activée
SIEM	Réception des flux de journalisation, aucune capacité d'initier une connexion sortante vers les machines supervisées

Dans tous les cas : appliquer le principe de moindre privilège aux comptes de service.

3.8 Journalisation

- Configurer l'envoi des journaux pertinents (auth, application, pare-feu local) vers le segment de supervision (SIEM), en flux strictement sortant.
- Vérifier que le serveur ne peut pas recevoir de connexion initiée depuis le SIEM.
- Confirmer la synchronisation NTP (horodatage cohérent entre serveurs, indispensable à la corrélation d'événements).

3.9 Sauvegarde

Si le serveur héberge des données à sauvegarder (ex. SRV-2) :

- Confirmer que la sauvegarde est initiée en mode pull depuis le serveur Backup, jamais en push depuis le serveur source.
- Restreindre la commande SSH utilisée pour la sauvegarde (commande forcée / restreinte, pas de shell interactif).
- Vérifier la rétention et le chiffrement du dépôt Borg cible.

4. Liste de tests

Aucun déploiement n'est considéré comme terminé avant l'exécution complète des tests suivants, avec snapshot horodatée.

4.1 Tests de connectivité et de conformité réseau

Test	Objectif	Méthode
Isolation inter-segments	Confirmer qu'aucun flux ne contourne le pare-feu périmétrique	nmap depuis un autre segment vers le serveur cible ; seuls les ports explicitement autorisés doivent répondre
Absence de réponse aux flux non autorisés	Valider la politique deny-by-default	telnet/netcat sur des ports non listés dans la matrice de flux : connexion refusée ou timeout attendu
Redirection de port (si applicable)	Valider le comportement PREROUTING (ex. 80→5000)	Requête curl externe sur le port exposé, vérification de la réponse applicative

4.2 Tests d'authentification

Test	Objectif	Méthode
Rejet de l'authentification par mot de passe	Confirmer PasswordAuthentication no	Tentative de connexion SSH par mot de passe : doit échouer
Authentification par certificat	Confirmer le fonctionnement de la PKI	Connexion SSH avec une clé utilisateur signée valide : doit réussir
Rejet d'une clé non signée	Confirmer TrustedUserCAKeys	Connexion avec une clé utilisateur non signée par la CA : doit échouer

4.3 Tests fonctionnels applicatifs

- Redémarrage complet du serveur et vérification de la persistance des données et de la disponibilité du service (démon systemd ou équivalent).
- Pour SRV-1/SRV-2 : test de bout en bout applicatif (dépôt et consultation d'un message via l'interface web).
- Pour Backup : exécution d'un cycle de sauvegarde complet suivi d'une restauration test dans un environnement isolé.

4.4 Tests de conformité sécurité

- Vérification que le compte de service ne dispose pas de privilèges superflus (ex. : rôle applicatif BDD sans droits Superuser/Create role).
- Revue des règles iptables actives (iptables -L -n -v) après redémarrage comparée au script versionné de référence.
- Confirmation que les journaux du serveur remontent effectivement vers le SIEM (test d'événement de bout en bout).

4.5 Checklist récapitulative

- ☐ Serveur provisionné sur segment isolé, snapshot pré-durcissement pris
- ☐ Système mis à jour, services inutiles désactivés

- ☐ SSH durci (port 2222, PermitRootLogin no) avant rattachement réseau élargi
- ☐ Interface pfSense assignée et correspondance MAC vérifiée
- ☐ Certificat d'hôte SSH déployé et sshd_config mis à jour
- ☐ TrustedUserCAKeys déployé, authentification par mot de passe désactivée
- ☐ Règles iptables locales appliquées et persistées
- ☐ Déploiement applicatif spécifique au rôle effectué avec compte à moindre privilège
- ☐ Journalisation vers le SIEM opérationnelle (flux sortant uniquement)
- ☐ Sauvegarde configurée en mode pull si applicable
- ☐ Tests de connectivité, d'authentification, fonctionnels et de conformité sont exécutés et documentés
- ☐ Preuves horodatées archivées (captures, logs)

4.6 Références

- ISO/IEC 27001 — Annexe A, notamment A.8.9 (gestion de configuration), A.8.20 (sécurité des réseaux), A.8.22 (cloisonnement des réseaux), A.5.37 (procédures d'exploitation documentées)
- Matrice de flux et diagramme des périmètres de sécurité — Document HLD du projet AIS